

# Nexus Shield — Yapay Zeka Ajanı Eylem Yönetiřimi ve Doğrulama Platformu

Ajanlarınızın ne yapmasına izin verildiğini bilin. Yapmamaları gerekenleri durdurun. Ne olduğunu kanıtlayın.

Kurumsal mimari özeti · CISO / CTO brifingi

<https://www.nexusshield.ai/> · Gizli — paydaş incelemesi içindir

# Introduction

Resmi site: <https://www.nexusshield.ai/>

Canlı panel: <https://nexus-shield-dashboard.vercel.app>

Belge sınıfı: CISO / CTO / üst yönetim brifingi · mimari genel bakış

PDF üretimi: `python scripts/generate_enterprise_deck.py --lang tr`

## 1. Yönetici Özeti ve Temel Konumlandırma

### Resmi ad

Nexus Shield — Yapay Zeka Ajanı Eylem Yönetişimi ve Doğrulama Platformu

### Temel motto

*Ajanlarınızın ne yapmasına izin verildiğini bilin. Yapmamaları gerekenleri durdurun. Ne olduğunu kanıtlayın.*

### Altyapı taahhüdü

Sizin yapay zeka ajanlarınız. Sizin altyapınız. Sizin veriniz. Sizin politikalarınız.

### Konumlandırma dönüşümü

| Eski çerçeve (kullanımdan kalkmış)      | Nexus Shield çerçevesi                                      |
|-----------------------------------------|-------------------------------------------------------------|
| Genel “yapay zeka güvenliği”            | Araç yürütme sınırında ajan eylem yönetişimi                |
| Yalnızca istem (prompt) güvenlik duvarı | Her araç çağrısında niyet doğrulama + politika kararı       |
| Log saklama                             | SHA-256 evidence_hash ile Evrensel Eylem Makbuzu (UAR)      |
| Opak engelleme oranları                 | Şeffaf Proof Center — kıyaslama hattı vs üretim UAR defteri |

Üst akış LLM denetimi, KVKK/GDPR kapsamında PII maskeleye ve yönlendirici korkulukları destekleyici Güvenlik Motorları olarak kalır. Birincil ürün nesnesi UAR’dır — ne denendiği, politikanın ne karar verdiği ve durumun nasıl değiştiğinin kriptografik olarak mühürlü kaydı.

### Yönetici sonuçları

- Yönet: Otonom ajanların CRM, veritabanı, ödeme API’leri ve MCP araç yüzeylerinde neleri çalıştırabileceğini tanımlayın.
- Durdur: BLOCK, uyarlamalı READ\_ONLY, REQUIRE\_APPROVAL veya filo kill switch uygulayın — yalnızca sohbet loglarından tahmin etmeyin.
- Kanıtla: SIEM uyumlu kanıt dışı aktarın, /verify üzerinde makbuz doğrulayın; ekran görüntüsü değil, tekrarlanabilir hash ile denetim taleplerini karşılayın.

### Kesin ürün tanımı (CISO / CTO)

Nexus Shield genel bir “yapay zeka güvenliği” veya yalnızca istem güvenliğini ölçen bir LLM güvenlik duvarı değildir. Araç yürütme anına odaklanan bir Yapay Zeka Ajanı Eylem Yönetişimi ve Doğrulama Platformudur:

- Araç yürütme kontrolü — yan etkili her MCP / API çağrısı çalışmadan önce değerlendirilir.
- Parametre ele geçirme — araç adı veya argümanların bildirilen niyetten sapmasının tespiti.
- Niyet sapması — uyumsuzluğun ölçülmesi (ör. %96) ve kademeli politika uygulaması.

İstem filtreleme sohbet katmanı riskini azaltabilir; eylem sınırındaki yönetişimin yerini tutmaz.

## Hava boşluklu ve self-hosted güven taahhüdü

Veri düzlemi (nexus) varsayılan olarak hava boşluklu ve self-hosted tasarlanmıştır.

| Taahhüt            | Detay                                                                                            |
|--------------------|--------------------------------------------------------------------------------------------------|
| Varsayılan duruş   | NEXUS_AIRGAP=true, NEXUS_CLOUD_CONNECT=false (deployments/)                                      |
| Veri yerleşimi     | Ajan istemleri, araç yükleri, politikalar ve UAR defteri VPC / küme / şirket içi sınırdaki kalır |
| İsteğe bağlı bulut | Kontrol düzlemi varsayılan kapalı                                                                |
| Her yerde dağıtım  | Docker Compose veya Helm — sizin API taban URL'niz                                               |

CISO sorusu: “Ajan verimiz kurumsal sınırı terk eder mi?” — Self-hosted veri düzlemi ile hayır (varsayılan hava boşluğu).

## 2. Önce ve Sonra — Gerçek Dünya Senaryosu

### Nexus Shield öncesi — bugünkü risk

LangChain, CrewAI veya özel orkestrasyon ile bağlı bir ajan prompt injection veya planlayıcı hırsızlığı yaşar; yetkisiz veritabanı yazımı veya MCP ile veri sızdırma aracı çalışır. Loglarda yalnızca “LLM yanıt üretti” görünür; niyet, araç, karar ve durum arasında kriptografik bağ yoktur. Operasyon filoyu dondurur veya kapatır; hukuki ekip savunulabilir kanıt bulamaz.

### Nexus Shield sonrası — yarının kontrolü

Veri düzlemi çağrısı yakalar (POST /api/v1/action/evaluate veya self-hosted POST /v1/intercept):

1. Niyet bildirilir · 2. Araç önerilir · 3. Sapma tespit edilir (ör. %96) · 4. BLOCK veya READ\_ONLY / REQUIRE\_APPROVAL · 5. SHA-256 UAR · 6. /verify ve SIEM dışı aktarımı.

| Boyut             | Önce              | Sonra                                   |
|-------------------|-------------------|-----------------------------------------|
| Görünürlük        | “Model yanıtladı” | Niyet → araç → karar → durum → UAR      |
| Müdahale          | Filo kapatma      | BLOCK, READ_ONLY, onay kuyruğu          |
| Denetim savunması | Anecdote          | evidence_hash, doğrulanabilir kanıt     |
| Veri sınırı       | Belirsiz egress   | Self-hosted, hava boşluklu veri düzlemi |

## 3. Evrim ve Gelişim Yolculuğu

## Faz 1 — LLM korkulukları (temel)

Erken çalışmalar prompt injection, PII sızıntısı ve temel LLM vekil desenlerine odaklandı. Sohbet katmanı riski için değerli; ancak ajanlar araç yürütme ve kalıcı kimlik bilgileri kazandığında yetersiz kaldı.

## Faz 2 — Kurumsal sorun keşfi (ajanik sınır)

Müşteri ve red-team geri bildirimleri farklı bir risk sınıfında birleşti:

- Araç kötüye kullanımı ve MCP sunucu ele geçirme (LangChain, CrewAI, özel ajanlar).
- Zincirlenmiş araç çağrılarıyla yetki yükseltme.
- Niyet / eylem sapması — bildirilen iş hedefi vs yıkıcı veya sızdırma aracı.
- Operasyonel ikilem: tüm ajanı kapatmak vs READ\_ONLY düşürme vs insan-onaylı döngü.

Nexus Shield “istemleri filtrele”den eylemleri yönete döndü.

## Faz 3 — Harness vs runtime ayrışması

Açık kaynak nexus-harness-benchmark (harness/) üretim Action Firewall'dan açıkça ayrıldı:

- Harness = tekrarlanabilir skorlar, CVE tarzı preset'ler, MCP-SEC-SCORE lider tabloları.
- Runtime = canlı yakalama, kiracı RBAC, yerel UAR defteri.

Bkz. BENCHMARK\_VS\_ACTION\_FIREWALL.md.

## Faz 4 — Kurumsal olgunluk (kriptografi ve düzlemler)

| Kilometre taşı          | Yetenek                                                                                                                       |
|-------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| cc20ed6044              | Veri düzlemi paketleme (Docker / Helm), UAR kanıt zinciri, SIEM uyum JSONL, dağıtım dokümantasyonu                            |
| 0d16526309              | Yapay Zeka Ajanı Eylem Yönetişi ve Doğrulama konumlandırması; UAR_SCHEMA.md                                                   |
| 4b46946548 / ef22090ffa | Proof Center metin şeffaflığı — kanıt paketleri değerlendirilen yörünge adımlarına göre, yalnızca “engellenen eylemler” değil |

Bugün: veri düzlemi (nexus) varsayılan olarak hava boşluklu çalışır; kontrol düzlemi (nexus-control) lisans ve imza senkronu için isteğe bağlıdır.

## 4. Kurumsal Problem ve Hedef Pazar

## Hedef pazar

| Segment       | Nexus Shield gerekçesi                                                     |
|---------------|----------------------------------------------------------------------------|
| Finans        | Havale, toplu dışa aktarma araçları, SOX / PCI denetim izleri              |
| Sağlık        | Ajan araçları üzerinden PHI erişimi, asgari gerekli ilke                   |
| Kurumsal SaaS | Müşteri CRM / faturalama API'lerine dokunan çok kiracılı ajanlar           |
| Otonom DevOps | Üretim veritabanı veya bulut kontrol düzlemi araçlarına erişen CI ajanları |

## Çözülen problemler

- Yetkisiz araç yürütme — politika dışı yaz/sil/dışa aktar araçları.
- Niyet sapması — planlayıcı veya enjekte bağlam, bildirilen iş niyetinden ayrılır.
- Denetim izi eksikliği — niyet, araç, karar ve durum arasında kriptografik bağ yok.
- İkili olay müdahalesi — “ajanı kapat” yerine kademeli uygulama (READ\_ONLY, onay kuyrukları, kapsamlı iptal).
- Uyumluluk kanıtı açığı — SOC 2 / ISO 27001 / KVKK-GDPR talepleri dışa aktarılabilir, doğrulanabilir artefaktlar ister.

## 5. Depo Ekosistemi (Açık Kaynak ve Kurumsal Yığın)

| Kod adı                 | Yol / paket                                                    | Rol                                                                                             |
|-------------------------|----------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| nexus                   | enterprise/data_plane_api.py,<br>politika motoru, uar_store.py | Veri düzlemi — yönetim, UAR mühürleme, yerel defter, POST /v1/intercept                         |
| nexus-control           | enterprise/cloud_panel.py,<br>tenant_manager.py                | Kontrol düzlemi (isteğe bağlı) — orkestrasyon, RBAC, SIEM, NEXUS_CLOUD_CONNECT=true iken lisans |
| nexus-agent-sdk-python  | packages/python (pip install<br>nexus-shield)                  | Python SDK — eylem değerlendirme, yetenek haritalama, yakalama                                  |
| nexus-agent-sdk-bridge  | packages/npm                                                   | Node / Vercel AI SDK köprüsü — MCP ve HTTP vekil desenleri                                      |
| nexus-harness-benchmark | harness/                                                       | Yalnızca değerlendirme — 500+ MCP saldırı senaryosu, çok ajanlı grafikler                       |

Destekleyici yüzeyler:

- nexus-shield-dashboard/ — Proof Center arayüzü, Trust Hub, /demo, /verify, /scan.
- presets/ — Deterministik CVE tarzı zafiyet gösterimleri.
- deployments/ — Şirket içi / hava boşluklu Docker Compose ve Helm.

## 6. Site Modülleri ve Etkileşimli Hunisi

Paneldeki genel ve kimlik doğrulamalı modüller (nexus-shield-dashboard/lib/dashboard-nav.ts):

| Modül                | Rota                                         | Amaç                                                                                                       |
|----------------------|----------------------------------------------|------------------------------------------------------------------------------------------------------------|
| Kurulum Rehberi      | /dashboard                                   | Onboarding, entegrasyon kontrol listesi                                                                    |
| Ücretsiz Tarama      | /scan                                        | Saldır → Kanıtla → Kur → Korum — ajan uç noktaları, MCP yapılandırmaları, aşırı yetki için GitHub yamaları |
| Ajanlar              | /dashboard/agents                            | Filo görünürlüğü, yetenek haritaları                                                                       |
| Action Firewall      | /dashboard/actions                           | Canlı politika, yakalama geçmişi                                                                           |
| Tehdit İstihbaratı   | /dashboard/threat-intel                      | Toplu saldırı kalıpları, bağışıklık hafızası                                                               |
| Red Team             | /dashboard/simulator                         | Sentetik saldırı vektörleri, simülatör                                                                     |
| Proof Center         | /proof-center                                | Açık harness metrikleri + metodoloji                                                                       |
| Trust Hub            | /dashboard/trust-hub                         | Yönetişim denetim izi, makbuz doğrulama                                                                    |
| Uyumluluk            | /dashboard/compliance                        | SOC 2 / ISO raporlama, KVKK/GDPR kanıt dışı aktarımı                                                       |
| Challenge Engine     | /challenge (API:<br>/api/challenge/evaluate) | 7 seviyeli saldırı koruması ve topluluk lider tablosu                                                      |
| Tespit ve Göster     | /demo                                        | CVE preset'leri, bağımsız /verify URL'leri                                                                 |
| Yatırımcı metrikleri | /investor                                    | Büyüme ve kıyaslama şeffaflığı                                                                             |

## Temel runtime API'leri

| Uç nokta                     | Düzlem                           | Açıklama                                               |
|------------------------------|----------------------------------|--------------------------------------------------------|
| POST /api/v1/action/evaluate | Panel / yönetilen API            | Gerçek zamanlı araç değerlendirme → UAR zarfı          |
| POST /v1/intercept           | Self-hosted veri düzlemi (:8090) | Müşteri altyapısında aynı yönetim semantiği            |
| POST /api/v1/agent/trust     | Panel                            | Yönetilen olay sonrası itibar / MCP-SEC-SCORE          |
| GET /verify                  | Genel                            | Makbuz hash varlık kontrolü (receipt_hash, receipt_id) |

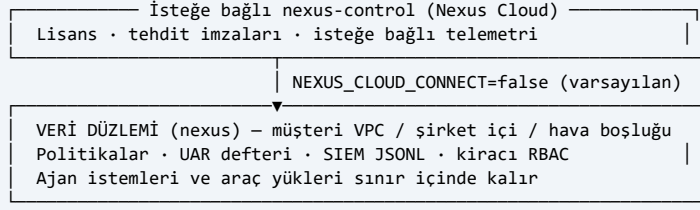
## 7. Dağıtım Mimarisi — Self-Hosted, Hava Boşluklu ve Özel Bulut

### CISO güven garantisi (mimari)

- Veri düzlemi (nexus) — yönetim zorunlu: yakalama, UAR, RBAC, SIEM. NEXUS\_AIRGAP=true ile ortamınızda çalışır.
- Kontrol düzlemi (nexus-control) — isteğe bağlı; engelleme ve makbuz için gerekli değildir.

NEXUS\_CLOUD\_CONNECT=false iken ajan istemleri, araç argümanları ve API yükleri Nexus Shield SaaS'a gönderilmez. Güven sınırı sizin küme sınırınızdır.

### Veri düzlemi vs kontrol düzlemi



## Hava boşluklu / şirket içi

deployments/ dizininden:

```
cd deployments
NEXUS_AIRGAP=true NEXUS_CLOUD_CONNECT=false docker compose up -d
curl http://localhost:8090/healthz
```

Helm (AWS EKS, Azure AKS, GCP GKE veya özel veri merkezleri):

```
helm upgrade --install nexus-shield ./k8s/nexus-shield \
--set global.airgap=true \
--set nexusCloud.connect=false
```

| Değişken                   | Varsayılan | Anlam                                          |
|----------------------------|------------|------------------------------------------------|
| NEXUS_AIRGAP               | true       | İsteğe bağlı bulut çıkışını kapat              |
| NEXUS_CLOUD_CONNECT        | false      | Kontrol düzlemi kapalı — tamamen yerel yönetim |
| NEXUS_DATA_PLANE_BOOTSTRAP | true       | İlk yakalama için yerel demo kiracısı          |

Kanıt birimleri: nexus-enterprise-data, nexus-enterprise-logs.

## Özel API adresleri ve ağ geçidi entegrasyonu

Kurumlar ajanları kendi taban URL'lerine yönlendirir:

- Dahili API ağ geçidi → <https://nexus.internal.sirket.com/v1/intercept>
- Ajan pod'larıyla yan konteyner (Kubernetes)
- MCP vekili: araç sunucularının önünde bridge SDK

Veri düzlemi self-hosted iken `api.nexusshield.ai` zorunlu değildir. LLM yönlendirici + araç yolu için `GATEWAY_INTEGRATION.md`.

## 8. Evrensel Eylem Makbuzu (UAR) ve Proof Center Şeffaflığı

## Üretim UAR alanları

| Alan              | Açıklama                                                      |
|-------------------|---------------------------------------------------------------|
| receipt_id        | Kararlı makbuz kimliği (uar_...)                              |
| agent_id          | Yönetilen ajan                                                |
| intent            | Bildirilen kullanıcı / iş niyeti (API'de user_intent)         |
| proposed_action   | İstenen araç + parametreler                                   |
| intent_divergence | risk_score, violations, sapma metrikleri (ör. %96 uyumsuzluk) |
| decision          | ALLOW · BLOCK · READ_ONLY · REQUIRE_APPROVAL                  |
| execution_state   | before_hash, after_hash, execution_status                     |
| evidence_hash     | SHA-256 mühür (evidence_bundle_hash)                          |

Yönetilen her eylem denemesi UAR alır — yalnızca engellemeler değil.

### Proof Center — iki hat (karıştırmayın)

| Hat                                 | Temsil metrikleri                                      | Anlam                                                                |
|-------------------------------------|--------------------------------------------------------|----------------------------------------------------------------------|
| Tekrarlanabilir kıyaslama sonuçları | 127 ajan · 48.291 araç çağırısı / harness kanıt paketi | Açık harness değerlendirilen yörünge adımları (tüm karar türleri)    |
| Tehlikeli eylem kıyas alt kümesi    | 3.817 / 3.842 tehlikeli eylem engellendi (%99,3)       | Saldırı senaryosu engelleme oranı — toplam kanıt sayısına eşit değil |
| Deterministik UAR defteri           | Kiracı başına uar_receipts.json1                       | Sizin üretim denemeleriniz, kararlarınız, mühürleriniz               |

Genel arayüz metni: “Değerlendirilen her ajan yörüngesi ve yönetilen eylem denemesi, değiştirilemez bir SHA-256 kanıt paketi üretir.”\*

## 9. Uçtan Uca Demo Senaryoları ve İş Akışları

### İş akışı A — Canlı yakalama (yönetici demosu)

- Niyet yakalama — Operatör niyet bildirir (ör. “Salt okunur fatura özeti”).
- Araç çağırısı — Ajan export\_customer\_database veya MCP eşdeğerini ister.
- Yakalama — POST /api/v1/action/evaluate veya self-hosted POST /v1/intercept.
- Niyet sapması — Politika motoru risk hesaplar (ör. %96 sapma, INTENT\_ACTION\_DIVERGENCE).
- Politika uygulama — BLOCK veya filo kapatma yerine READ\_ONLY / REQUIRE\_APPROVAL.
- UAR üretimi — SHA-256 evidence\_hash, saklanan makbuz, isteğe bağlı SIEM.
- Doğrulama — /verify?receipt\_hash=...&receipt\_id=... veya GET /v1/receipts/{id}/verify.
- Güven güncelleme — POST /api/v1/agent/trust itibar / MCP-SEC-SCORE günceller.

## İş akışı B — CVE preset (Tespit ve Göster)

```
python scripts/simulate_vulnerability_preset.py --preset cve-2026-critical-zero-day --write-public-json
```

/demo ve genel doğrulama linkleri için deterministik kanıt JSON — sorumlu açıklama provası için ideal.

## İş akışı C — Satın alma için hava boşluğu kanıtı

1. Müşteri lab'ında deployments/docker-compose.yml dağıtın.
2. localhost:8090 üzerinde intercept curl çalıştırın.
3. Dış bulut olmadan yerel JSONL defter + uyumluluk denetim logunu gösterin.
4. Yalnızca lisans eşleme için isteğe bağlı NEXUS\_CLOUD\_CONNECT=true ile karşılaştırın.

## Ek — Temel dokümantasyon haritası

| Belge                           | Konu                         |
|---------------------------------|------------------------------|
| UAR_SCHEMA.md                   | Kanonik makbuz alanları      |
| DATA_PLANE_AND_CONTROL_PLANE.md | Hava boşluklu mimari         |
| BENCHMARK_VS_ACTION_FIREWALL.md | Harness vs runtime           |
| GATEWAY_INTEGRATION.md          | Kurumsal ağ geçidi yerleşimi |
| COMPLIANCE_READINESS.md         | SOC 2 / ISO hizalama         |
| DETECT_AND_DEMONSTRATE_PROOF.md | Demo + doğrulama hattı       |

İletişim: Demo randevusu · nexusshield.ai